

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 1 頁，共 14 頁

單選題 50 題 (佔 100%)

D	1. 有關防止 OWASP Top 10 的 A02:2021-Cryptographic Failures 漏洞之敘述，下列何者錯誤？ (A) 確保將所有的機敏資料加密 (B) 使用最新版且標準的強加密演算法 (C) 使用適當的金鑰管理 (D) 使用 HTTP 的協定加密傳輸中的資料
D	2. 下列何項「不」是過濾型網路防火牆所過濾的網路封包參數？ (A) 來源端 IP Address (B) 目的端 IP Address (C) 來源端 TCP/UDP Port (D) 目的端 MAC Address
C	3. 下列何項是正確的防火牆策略設定機制？ (A) 經適當的申請流程後即可無限期使用 (B) 保護服務主機的防火牆，可預設允許由主機連出 internet 的連接 (C) 防火牆策略應由受過專業訓練的人員審核及設定 (D) 「黑名單」的設定方式優於「白名單」
B	4. 在殭屍網路 (Botnet) 的架構中，攻擊者通常會將惡意軟體散佈到多台受害者電腦上，將這些受感染的電腦轉變為「殭屍電腦」。當攻擊者累積足夠數量的殭屍電腦後，通常會透過一台「中介主機」來下達指令，進而發動對特定目標的網路攻擊。請問下列何項是這種中介主機的專有名稱？ (A) SQL 伺服器 (B) C&C (Command and Control) 伺服器 (C) DNS (Domain Name System) 伺服器 (D) FTP (File Transfer Portocal) 伺服器

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：II2 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 2 頁，共 14 頁

D

5.

附圖為防火牆的過濾規則表及封包資訊。在判斷封包是否通過防火牆時，請根據規則表來決定並選擇正確的選項。請問該封包依據防火牆規則是否通過，以及符合哪條規則？

防火牆過濾規則表

規則	來源 IP 位址	目的 IP 位址	類型	來源埠編號	目的埠編號	結果
1	20.210.21.72	*	*	*	*	拒絕
2	140.130.149.*	140.112.*	TCP	*	23	通過
3	140.112.*	140.130.149.*	TCP	23	*	通過
4	140.*	140.*	TCP	*	25	通過
5	*	*	*	*	*	拒絕

封包資訊：

來源 IP 位址：120.132.78.54

目的 IP 位址：140.130.149.60

封包類型：UDP

來源埠編號：1692

目的埠編號：53

(A) 通過，符合規則 1

(B) 通過，符合規則 3

(C) 通過，符合規則 4

(D) 被拒絕，符合規則 5

C

6.

關於網路安全敘述，下列何者較「不」適當？

(A) 網路安全包含：網路裝置安全、網路資訊安全、網路軟體安全

(B) 駭客可透過網路的入侵來達到竊取敏感資訊的目的

(C) 好的網路安全設計只需要單層防護即可

(D) 開啟電子郵件時，相關附件或連結務必小心判別

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 3 頁，共 14 頁

B	7. 在釣魚攻擊中，攻擊者通常會使用下列何種方式來欺騙受害者？ (A) 直接入侵受害者的電腦 (B) 假冒合法機構發送電子郵件 (C) 利用病毒感染受害者的系統 (D) 竊取網路流量
B	8. 下列哪一種攻擊手法是利用「不」安全的無線網路來竊取資料？ (A) 拒絕服務攻擊 (Denial of Service, DoS) (B) 中間人攻擊 (Man-in-the-Middle attack, MITM) (C) 跨站腳本攻擊 (Cross-Site Scripting, XSS) (D) SQL 注入攻擊 (SQL Injection)
A	9. 有關 OSI 模型中會議層 (Session Layer) 之敘述，下列何者正確？ (A) 主要的功能是負責管理和控制不同應用程式之間的對話 (B) 確保資料傳輸的可靠，並處理錯誤復原 (C) 處理封包的路由與轉發 (D) 將資料進行壓縮與解壓縮以提高傳輸效率
C	10. 下列哪一種攻擊行為屬於 OSI 第七層 (應用層) 的 DDoS 攻擊手法？ (A) SYN Flood Attack (B) Fragmentation Attack (C) HTTP Flood Attack (D) UDP Flood Attack
A	11. 在通訊安全中，「完整性」指的是下列何項？ (A) 確保數據資料在傳輸過程中未被未經授權的修改 (B) 確保網站的可用性，可隨時存取網站 (C) 確保所有使用者都有依最小原則設定權限 (D) 確保網絡傳輸速度與申請速率相符

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 4 頁，共 14 頁

A	12. 在通訊安全中，端對端加密（End-to-End Encryption, E2EE）的意思是下列何項？ (A) 數據資料在傳輸過程中始終被加密 (B) 只有發送端可以解密數據資料 (C) 數據資料在加密設備上加密，然後傳輸 (D) 數據資料在傳輸過程中不會被加密
B	13. 在防火牆的深度封包檢查（Deep Packet Inspection, DPI）技術中，下列哪一項是其主要目的？ (A) 僅檢查封包的標頭資訊 (B) 分析封包的內容以識別應用層協定和潛在威脅 (C) 僅過濾基於 IP 位址的流量 (D) 提供使用者身份驗證功能
A	14. 當電腦 A 位於防火牆 B 後面，只想要開放電腦 A 上的遠端桌面服務，供外部使用者可以從網際網路連線進入時，防火牆 B 應該設定下列何種功能最合適？ (A) Port Mapping (B) Virtual Server (C) DHCP (D) DNS
B	15. 關於 Linux 檔案的敘述下列何者錯誤？ (A) /etc/shadow：儲存使用者密碼的 Hash 值 (B) /bash_history：使用者登入的歷史紀錄 (C) /var/log/secure：檔案用於記錄與安全相關的所有事件，包含使用者登入紀錄 (D) /.ssh/known_hosts：記錄對方連線主機的指紋資訊

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 5 頁，共 14 頁

C	16. 某網站存在跨站請求偽造（Cross Site Request Forgery, CSRF）漏洞，攻擊者可能會利用該漏洞發起攻擊。下列何種方法最常用來防止 CSRF 攻擊？ (A) 在 URL 中加入 Session ID (B) 將所有表單設為唯讀權限（Read only） (C) 在使用者的請求中加入 Token (D) 將所有網頁設置為不可被搜索引擎索引
D	17. 在網路中，路由器（Router）是一種常見的網路硬體設備。下列何項是路由器的主要功能？ (A) 分配 IP 位址給網路中的裝置 (B) 在區域網路（LAN）中將資料封包轉送到正確的裝置 (C) 為網路中的所有資料封包加密 (D) 負責將資料封包從一個網路轉送到另一個網路
C	18. 關於 Linux 作業系統中檔案權限的敘述，下列何者正確？ (A) 檔案是否刪除，依據的權限值為檔案的 write 權限值 (B) 只要是副檔名為.exe 的二進位檔案，均可執行 (C) 檔案是否可以被使用者新增，需看該檔案所在的工作目錄是有給予使用者 write 權限 (D) root 使用者不可刪除一般使用者 home 目錄
B	19. 依據 OWASP Top 10 有關安全配置錯誤風險之敘述，當應用程式處於以下何種狀態時，該應用程式可能容易受到攻擊？ (A) 啟用或安裝了必要的功能 (B) 預設帳號及密碼仍處於啟用狀態 (C) 系統最新的安全功能被啟用 (D) 伺服器發送安全標頭或指令

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 6 頁，共 14 頁

C	20. PHP 程式語言中有好幾個可以用來執行作業系統指令的危險函數，使用的時候必須非常謹慎，如果程式撰寫不當，有機會被攻擊者拿來利用，進一步取得網頁伺服器的控制權。請問下列哪一個語法不是用來執行作業系統指令的 PHP 函數？ (A) system (B) passthru (C) eval (D) popen
C	21. 作業系統在更新軟體、韌體時，下列敘述何者錯誤？ (A) 可以透過 Hash 確認完整性 (B) 可以在測試機先做升級測試 (C) 看到升級提醒信件可以直接進行升級 (D) 同時可以更新 SBOM (Software Bill of Materials) 清單
C	22. 下列哪一種攻擊手法會利用應用程式的權限設定不當，讓攻擊者取得對應用程式或作業系統的未授權存取，並可能進一步提權成為系統管理員？ (A) 點擊劫持攻擊 (Clickjacking) (B) 旁通道攻擊 (Side-channel Attack) (C) 特權提升攻擊 (Privilege Escalation) (D) 特洛伊木馬攻擊 (Trojan Horse)
D	23. 要管理好資料庫系統，除了對資料庫系統有深度認知之外，仍需要了解資料庫系統所面臨的安全威脅。下列何項較「不」屬於資料庫系統所面臨的安全威脅？ (A) 資料庫內資料外洩 (B) 資料庫內的資料遭非法篡改與偽造 (C) 資料庫推論 (Database Inference) (D) 資料庫管理人員不具有作業系統操作認證

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 7 頁，共 14 頁

D	24. 軟體組成分析 (Software Composition Analysis, SCA) 主要是針對程式設計的哪一個部分進行分析？ (A) 所開發的原始碼是否有設計缺陷 (B) 編譯後的執行檔是否有錯誤配置 (C) 針對二進位檔進行 Security Hardening 檢查 (D) 軟體元件是否有已知漏洞
B	25. 若想要針對駭客反組譯程式的威脅，下列何者較「無法」達到有效保護？ (A) 執行檔加密保護 (B) 遵循程式碼安全開發指引 (C) 程式碼混淆 (D) 二進制檔案加殼保護
C	26. 當資料庫洩漏時，儲存在其中的使用者密碼，使用下列何種機制較「不」容易被輕易破解？ (A) 使用明文儲存密碼 (B) 使用對稱加密儲存密碼 (C) 使用加鹽式 (Salt) 雜湊函數後儲存密碼 (D) 使用 Base64 編碼儲存密碼
B	27. 黑箱測試是軟體開發常見的安全檢測方式。下列何項「不」是黑箱測試的特性？ (A) 檢測人員不需要具備應用程式開發知識與經驗 (B) 檢測人員必需知道該受測軟體內部結構，以利測出正確結果 (C) 檢測人員僅須從使用者角度，進行軟體介面、功能及外部結構進行測試 (D) 檢測人員必須利用有效輸入與無效輸入來驗證是否有正確的輸出結果

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 8 頁，共 14 頁

C	28. DevSecOps 是軟體開發過程中，每個階段整合安全測試的實務，它是 DevOps 實務的延伸。請問下列何項「不」包含在 DevSecOps 所定義的文化內容？ (A) 開發 (B) 安全性 (C) 規劃 (D) 營運
C	29. 軟體開發者設計的維護通道，被駭客利用程式存在的漏洞進出系統或網路，此攻擊模式稱為下列何項？ (A) 通道密碼攻擊 (B) 窮舉攻擊 (C) 後門攻擊 (D) 中間人攻擊
C	30. 請問下列哪一項防護措施是主要針對惡意程式的防護方法？ (A) 將所有電腦系統與網路斷開連接，避免受到外部攻擊 (B) 定期備份重要資料，防止資料遺失 (C) 安裝防毒軟體，並定期更新病毒碼 (D) 僅下載來自知名網站的檔案，避免受到釣魚攻擊
B	31. 下列哪一種密碼雜湊的強度最高、破解速度非常慢，即使用常見的密碼破解軟體 hashcat 來進行破解，也需要耗費非常久的時間才能破解出來？ (A) NTLM (B) bcrypt (C) MD5 (D) SHA1

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 9 頁，共 14 頁

D	32. 對惡意程式的管理方式，下列何項正確？ (A) 系統已安裝防範惡意程式偵測的軟體，不需要定期再執行掃描 (B) 定期蒐集到對系統軟體的威脅情資，無法做為防範惡意程式的來源依據 (C) 已於系統中安裝偵測惡意程式的防毒軟體，經由網路取得的資訊，使用前不需要額外進行掃描 (D) 定期實施社交工程測試，也是針對防範惡意軟體認知的提升
B	33. 為了防止企業遭受勒索軟體攻擊而發生損害，下列敘述何者較「不」適當？ (A) 啟用端點防護軟體（Endpoint Protection），並定期更新病毒定義庫，可阻擋已知的威脅 (B) 將所有的備份資料移至雲端，以避免勒索軟體威脅 (C) 對所有員工進行資安意識訓練，讓其識別釣魚郵件及可疑的附件，並啟用多重要素驗證（Multi-factor authentication, MFA），可降低被滲透機會 (D) 設定網路分區隔離（Network Segmentation），限制不同網段間的通信，可減少破壞範圍
C	34. 關於備份管理的目的，下列敘述何者錯誤？ (A) 防止資料丟失 (B) 提高資料可用性 (C) 複雜資料復原過程 (D) 提高業務連續性

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 10 頁，共 14 頁

B	35. 請問下列何種備份策略，在還原時，只要當次備份的檔案及上一次完整備份檔案即可完成資料的還原？ (A) 完整備份配合增量備份 (B) 完整備份配合差異備份 (C) 複製 (D) 差異備份配合增量備份
B	36. 關於備份媒體管理的描述，下列何項有誤？ (A) 備份媒體需要依照資訊機密性及完整性為考量，使用密碼式技術保護 (B) 備份媒體若為磁帶時，可以永久保存資料 (C) 備份至雲端空間，也可做為備份的一種資源 (D) 備份媒體銷毀流程時，亦需考量資料重要性選擇銷毀方式
A	37. 某員工平常使用筆記型電腦處理其公司業務，電腦上存放有公司的重要資料，但因工作需求，常需攜帶電腦至公司以外的場所使用，基於保護公司資料安全的考量，沒有獲得額外授權或指示的情況下，請問下列何項措施較「不」合適？ (A) 將資料同步至員工私人的雲端空間 (B) 將資料同步至公司配發的的雲端空間 (C) 啟用 BitLocker (D) BIOS 設定開機密碼
B	38. 企業在進行資料備份時，下列哪一種做法最能確保備份資料的安全性及完整性？ (A) 將所有備份儲存在與原始資料相同的伺服器上 (B) 定期將備份資料存放至異地儲存空間 (C) 為了快速完成備份，只在重要文件發生變更時才進行備份 (D) 備份後立即刪除原始資料，以節省儲存空間

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 11 頁，共 14 頁

D	39. 關於 Linux 日誌的相關描述，下列何者錯誤？ (A) /var/log/boot.log 記錄開機時系統核心偵測與啟動硬體，及各種核心支援的功能啟動等，只存放當次開機的資訊 (B) /var/log/cron 記錄 crontab 排程有沒有實際被進行 (C) /var/log/dmesg 記錄系統在開機的時候核心偵測過程所產生的各項資訊 (D) /var/log/messages 記錄系統上面所有的帳號最近一次登入系統時的相關資訊
C	40. 關於日誌管理會收攏許多 Log 記錄的敘述，下列何者正確？ (A) Web 網站日誌只收集網站流量和使用者的資訊，無法用在效能調教或是駭客入侵鑑識 (B) 網頁應用程式防火牆安全日誌，可以收到駭客惡意攻擊的訊息，無法探測潛在的漏洞攻擊活動 (C) 應用程式日誌，除可以記錄應用程式的錯誤訊息，也有機會用於除錯與效能的調校 (D) 作業系統日誌，以 Windows Event Log 類型來說，只可以收集安全、應用程式、系統等三類型記錄，無法自定義相關日誌

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 12 頁，共 14 頁

B

41. 有效管理來自伺服器、網路設備及應用程式等各種來源的日誌資訊可以提升資料的安全性並檢測威脅。請問下列有關日誌管理的描述何者有誤？
(A) 不同網路設備的日誌格式不同，Windows Event Viewer 就沒辦法直接開啟 Linux 系統的日誌
(B) 依據「資通系統防護基準驗證實務」規定，日誌的保存期限至少為 3 個月
(C) 任何發生在機關資通系統中可觀察到行為之結果稱為資通系統事件，應當具備有記錄特定事件之功能，並決定應記錄之特定資通系統事件
(D) 日誌應記錄資通系統管理者帳號所執行之各項功能

B

42. 最近某工程師發現他的電腦十分緩慢，當其查看事件檢視器如附圖，請問從附圖中的資料，可以確認的結論為下列何項？

關鍵字	日期和時間	來源	事件識別碼	工作類別
稽核失敗	2024/4/9 下午 01:28:23	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:28:23	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:28:11	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:28:11	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:27:56	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:27:56	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:27:48	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:27:48	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:27:46	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:27:46	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:27:35	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:27:35	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:27:24	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:27:24	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:27:14	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:27:14	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:27:01	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:27:01	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:26:48	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:26:48	Microsoft Windows security auditing.	4776	認證驗證

(A) 該電腦已經被入侵成功
(B) 有人嘗試登入該電腦，但都失敗
(C) 該電腦應該沒有問題
(D) 電腦中了木馬

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 13 頁，共 14 頁

D	43. 在日誌管理中，為了確保操作行為能被追蹤並歸責到特定使用者，下列哪一項做法較「不」適當？ (A) 使用唯一識別符碼，以確保使用者身份唯一 (B) 記錄每次操作的時間、使用者 ID 和具體動作 (C) 對所有事件，包括正常與異常行為，均進行詳細記錄 (D) 系統日誌的存取應妥善保護，並由最高權限的管理員帳戶維護管理
C	44. 企業若使用雲端服務作為企業資料的儲存，請問下列何項部屬模式更能確保機密性？ (A) 公有 (Public) 雲 (B) 自由 (Free) 雲 (C) 私有 (Private) 雲 (D) 混和 (Hybrid) 雲
C	45. 在雲端運算環境中，下列哪一項較「不」是常見的安全威脅？ (A) Distributed Denial of Service (DDoS) 攻擊 (B) API (應用程式介面) 的脆弱性 (C) 雲端實體主機的竊取 (D) 網路釣魚攻擊
B	46. 組織內員工可以使用個人擁有的智慧型手機或平板等行動裝置執行組織內的業務的狀況，可適應移動辦公趨勢，滿足現代行動化商務需求，其優點非常多，但不包括下列何項？ (A) 使用個人的行動裝置可以提高工作效率 (B) 個人裝置由個人保管，減少資料外洩的風險 (C) 減少組織購買設備的費用 (D) 組織透過行動裝置管理系統 (Mobile Device Management, MDM) 管理組織內的行動裝置，主要目的在於限制行動裝置可以從事的行為

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 14 頁，共 14 頁

C	47. 行動裝置常被作為雙因子認證（Two-Factor Authentication, TFA）的認證因子之一，請問下列何項「不」是行動裝置常用的認證開機方式？ (A) 人臉辨識 (B) 指紋辨識 (C) RFID 辨識 (D) 圖形辨識
C	48. 保護行動裝置避免遭受惡意軟體的攻擊，下列何項對策較「不」適當？ (A) 時常掌握應用程式的使用者對 APP 的評價 (B) 定期更新行動裝置作業系統和應用程式 (C) 每天更改裝置的鎖定密碼 (D) 避免連接到公共 Wi-Fi 網路
A	49. 物聯網架構具有三個層次，包含感知層、網路層、應用層，分別應用於 Bluetooth、Wi-Fi、4G 的加密保護機制為下列何項？ (A) LE Encryption；WPA/WPA2；EEA（EPS Encryption Algorithm） (B) AES；LE Encryption；WEP (C) LE Encryption；WPA/WPA2；SNOW 3G (D) KASUMI；SNOW 3G；WPA-PSK/WPA2-PSK
C	50. 駭客常使用下列何種技術破解物聯網中 Wi-Fi AP 的 WPA2 密碼？ (A) SQL 注入攻擊 (B) 分散式拒絕服務（DDoS）攻擊 (C) 字典攻擊（Dictionary Attack） (D) 跨站腳本攻擊（Cross-Site Scripting, XSS）